# bakery-example.com

Passive security audit by Loïc Tellier · 2026-10-16 · overall grade = weakest area

High exposure: priority fixes are needed.

| Overall | Website | Certificate & TLS | Email | Domain & DNS |
|---|---|---|---|---|
| **F** | **F** | **A** | **C** | **B+** |
| weakest area | 15/100 · Mozilla HTTP Observatory scoring | 90/100 · this project's scale (RFC 8996, certificate validity) | 55/100 · this project's scale (RFC 7208, 7489, 6376, 8461) | 80/100 · this project's scale (RFC 4033, 8659) |

0 critical · 11 to improve · 3 compliant · 10 info

## Priority actions

1. **Content-Security-Policy** (To improve)
   Define a CSP suited to the site, starting in "Report-Only" mode.
2. **HTTP to HTTPS redirect** (To improve)
   Set up a permanent (301) redirect from HTTP to HTTPS.
3. **HSTS** (To improve)
   Add "Strict-Transport-Security: max-age=31536000; includeSubDomains".
4. **Clickjacking protection** (To improve)
   Add "X-Frame-Options: SAMEORIGIN" or "frame-ancestors 'self'" in the CSP.
5. **SPF (authorized senders)** (To improve)
   Move to "~all", then "-all" once your senders are listed.
6. **DMARC (anti-spoofing policy)** (To improve)
   After a few weeks of report analysis, move to "quarantine", then "reject".
7. **DNSSEC** (To improve)
   Enable DNSSEC at your DNS host, then publish the DS record at your registrar (often a single option in their interface).
8. **HTTPS certificate** (To improve)
   Check that automatic renewal is in place.
9. **MTA-STS (encrypted email delivery)** (To improve)
   Publish an MTA-STS policy (in "testing" mode first), or enable it in your email service.
10. **CAA (allowed certificate authorities)** (To improve)
    Publish a CAA record naming the authority you use, e.g. 0 issue "letsencrypt.org".
11. **Software version disclosure** (To improve)
    Hide version numbers in the server configuration.

## Website security

| | | |
|---|---|---|
| To improve | **Content-Security-Policy**<br>Missing: no limit on which scripts the page can load (protection against XSS injection).<br>> Define a CSP suited to the site, starting in "Report-Only" mode.<br>Source: W3C Content Security Policy Level 3 | -25 pts |
| To improve | **HTTP to HTTPS redirect**<br>The site is still reachable over unencrypted HTTP, without a redirect.<br>> Set up a permanent (301) redirect from HTTP to HTTPS.<br>Source: MDN TLS guide: HTTP redirection | -20 pts |
| To improve | **HSTS**<br>Missing: the browser is not required to use HTTPS on later visits.<br>> Add "Strict-Transport-Security: max-age=31536000; includeSubDomains".<br>Source: RFC 6797 (HTTP Strict Transport Security) | -20 pts |
| To improve | **Clickjacking protection**<br>The site can be displayed inside a frame on another site (clickjacking risk).<br>> Add "X-Frame-Options: SAMEORIGIN" or "frame-ancestors 'self'" in the CSP.<br>Source: RFC 7034 (X-Frame-Options) | -20 pts |
| To improve | **Software version disclosure**<br>The server announces its versions (Server: Apache/2.4.41 (Ubuntu); X-Powered-By: PHP/7.4.3), which helps an attacker target known vulnerabilities.<br>> Hide version numbers in the server configuration.<br>Source: OWASP Secure Headers Project | not scored |
| Info | **Cookies**<br>No cookies set on the home page.<br>Source: RFC 6265 (HTTP cookies) and MDN cookie guide | 0 pts |
| Info | **Referrer-Policy**<br>Missing: browsers apply their default policy (strict-origin-when-cross-origin in recent versions).<br>> Add "Referrer-Policy: strict-origin-when-cross-origin" (worth bonus points).<br>Source: W3C Referrer Policy | 0 pts |
| Info | **Subresource Integrity**<br>No scripts on the home page.<br>Source: W3C Subresource Integrity | 0 pts |
| Info | **Cross-Origin-Resource-Policy**<br>Not set (optional; earns bonus points when set).<br>Source: MDN: Cross-Origin-Resource-Policy | 0 pts |
| Info | **Cross-Origin-Opener-Policy**<br>Not set (optional; earns bonus points when set).<br>Source: MDN: Cross-Origin-Opener-Policy | 0 pts |
| Info | **Cross-Origin-Embedder-Policy**<br>Not set (optional; earns bonus points when set).<br>Source: MDN: Cross-Origin-Embedder-Policy | 0 pts |

| | | |
|---|---|---|
| Info | **Permissions-Policy**<br>Missing: no restriction on access to browser features (camera, microphone, geolocation).<br>> Add for example "Permissions-Policy: camera=(), microphone=(), geolocation=()".<br>Source: W3C Permissions Policy | not scored |
| Compliant | **X-Content-Type-Options**<br>Present (nosniff).<br>Source: WHATWG Fetch: X-Content-Type-Options | 0 pts |

## Certificate & TLS

| | | |
|---|---|---|
| To improve | **HTTPS certificate**<br>The certificate expires in 20 days (2026-11-06).<br>> Check that automatic renewal is in place.<br>Source: MDN TLS guide | -10 pts |
| Compliant | **TLS protocol version**<br>Connection negotiated with TLSv1.3.<br>Source: RFC 8996 (deprecating TLS 1.0 and 1.1) | 0 pts |

## Email protection

| | | |
|---|---|---|
| To improve | **SPF (authorized senders)**<br>The SPF record ends with "?all" (neutral): it provides almost no protection.<br>> Move to "~all", then "-all" once your senders are listed.<br>Source: RFC 7208 (SPF) | -20 pts |
| To improve | **DMARC (anti-spoofing policy)**<br>"none" policy: DMARC monitors but blocks nothing.<br>> After a few weeks of report analysis, move to "quarantine", then "reject".<br>Source: RFC 7489 (DMARC) | -20 pts |
| To improve | **MTA-STS (encrypted email delivery)**<br>Not set: other mail servers may deliver your incoming email without encryption if an attacker tampers with the connection.<br>> Publish an MTA-STS policy (in "testing" mode first), or enable it in your email service.<br>Source: RFC 8461 (SMTP MTA Strict Transport Security) | -5 pts |
| Info | **DMARC: reports**<br>No report address (rua): you cannot see who sends email on your behalf.<br>> Add "rua=mailto:..." to receive aggregate reports.<br>Source: RFC 7489 (DMARC) | 0 pts |
| Info | **DKIM (email signing)**<br>No DKIM key found among the common selectors tested (16). This is not necessarily a problem: the selector may have another name.<br>> Check in your email service (Google Workspace, Microsoft 365...) that DKIM signing is enabled.<br>Source: RFC 6376 (DKIM) | not scored |
| Info | **TLS reporting (TLS-RPT)**<br>Not set: you are not told when other servers fail to deliver your mail securely.<br>> Publish a _smtp._tls TXT record, e.g. "v=TLSRPTv1; rua=mailto:tls-reports@your-domain".<br>Source: RFC 8460 (SMTP TLS Reporting) | not scored |
| Compliant | **Mail servers (MX)**<br>2 server(s): mx1.hosting-example.com, mx2.hosting-example.com<br>Source: RFC 7505 (null MX for domains that receive no email) | 0 pts |

## Domain & DNS

| | | |
|---|---|---|
| To improve | **DNSSEC**<br>Not enabled for bakery-example.com: DNS answers are not signed, so a resolver cannot detect forged answers (redirecting visitors or emails to another server).<br>> Enable DNSSEC at your DNS host, then publish the DS record at your registrar (often a single option in their interface).<br>Source: RFC 4033 (DNS Security Introduction and Requirements) | -15 pts |
| To improve | **CAA (allowed certificate authorities)**<br>No CAA record: any certificate authority may issue a certificate for this domain.<br>> Publish a CAA record naming the authority you use, e.g. 0 issue "letsencrypt.org".<br>Source: RFC 8659 (DNS Certification Authority Authorization) | -5 pts |

Method. Passive audit carried out by Loïc Tellier using public information only: DNS records, the certificate presented by the server and the home page. No intrusion testing was performed. Grades. The website grade follows the Mozilla HTTP Observatory (penalties and bonuses per header). The certificate, email and DNS grades use this project's own scale, based on the standards cited under each item. The overall grade is the lowest of the four. Limits. This audit does not cover the site's applications, workstations or user accounts. It gives an overview of the exposure visible from the Internet on the date shown.